

P02 transport/workflow requalification — 2026-09-23

Status: scoped local fixes verified; Block 2 remains in progress. This is a local candidate receipt, not acceptance of release Stack 02, its predecessor, the assembled product, or a completed Copilot checkpoint.

1. Identity and frozen scope

- Owner: Codex /root, keepkey-vault-v11-agent-1; canonical coordination claim docs/release/audit-claims/715-02/ OWNER.md in the main firmware worktree.
- Main firmware worktree: /Users/highlander/WebstormProjects/keepkey-stack/projects/keepkey-firmware. Its checkout has unresolved conflicts and was not used for code editing.
- Main template SHA256 at intake after the claim:
fbd340efde3c2e8ec0c0932c17e10b8c3b1592f3f25eb82562467d3ac7ae6d61.
- Isolated checkout: /private/tmp/kk715-p02-requalification-20260923; branch audit/p02-requalification-20260923.
- Frozen code/test candidate: 3ade6134877314293749af4e73de9ebf9d9de0c4. This report is generated after that commit. Later report-only commits do not change the checked implementation, tests, pins or workflows.
- Candidate base: 51411c4a7c96137bc80f8b99fa1690c4e385f7fd, published release Stack 02 [PR #832](#), branch release/715-stack-02-chains.
- PR #832's reported adjacent base at intake: 66ca726662822a9ff102bcd1354cc6a39d5a203b; 32 changed paths. This code-bearing PR is not synonymous with historical P02.
- Stack 01 [PR #831](#) current branch head: cec3cac2487356e0ffa556d201e5eab14f31e054. Stack 00b [PR #845](#) head: 4c56e19e3070772a28b2890a4ec862ecf77d5429. Both remained unaccepted at intake. Recheck before integration.
- Historical source: 614425a2a14d0113de251e7944118e47f31f5265. Historical receipt [PR #850](#) is documentation-only and cannot review this firmware delta.
- The Stack 02 source declares firmware **7.14.3**, despite its place in the 7.15 release program. Final host validation used FW_VERSION=7.14.3 and the emulator reports that version. Release naming is not a capability assertion.
- Scope: the five P02 contracts below, their local regressions, and device receive paths. Exclusions: full chains-feature acceptance, unrelated P03/P04/EVM policy repairs, predecessor policy redesign, shared-branch restacking, release publication and physical-device qualification.
- No shared release branch was pushed, reset, retargeted or merged. No external review was requested. The candidate remains local pending accepted predecessor reconciliation.

Dependency pins

No dependency pointer changed in this candidate. Required build dependencies were initialized at these exact pins; the combined old Stack 06 remediation's unpublished host pin was not imported.

Dependency	Commit
code-signing-keys	a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c
deps/device-protocol	dd9c85dc747cf965fb0e7bf49615dc9e7568ee65
deps/googletest	7888184f28509dba839e3683409443e0b5bb8948
deps/python-keepkey	49d537ce953b7524599bfc87f56b7a50a51a13a1
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

Nested host device-protocol: dd9c85dc747cf965fb0e7bf49615dc9e7568ee65; token list: 89a64f717e1690bb31adb3e4c38e23640357333c. Unused nested crypto vendor/test repositories were not build inputs.

2. Behavior-to-adjacent-diff coverage

Contract	Published Stack 02 reconciliation	Local candidate and coverage
Tiny credential bytes are erased and never reused	Retained from Stack 01: <code>messages.c</code> , <code>confirm_sm.c</code> , <code>pin_sm.c</code> , <code>passphrase_sm.c</code> , and USBRX. <code>TinyAcknowledgementDoesNotReusePreviousSecret</code> . Most wiping code is inherited, not new PR #832 code.	Existing wipe paths retained; native regression passes in both variants. Handler changes below preserve exit wipes. A future review must explicitly cover inherited wiping code.
Initialize/protected Ping revoke old signers; soft Initialize retains PIN policy	Initialize abort is already present in the Stack 00b base and retained. Protected Ping's explicit pre-wait abort is missing. Its regression was guarded.	Add pre-wait signing abort without clearing PIN policy; ungate the Ping regression. New soft-Initialize test proves Bitcoin signing and passphrase are cleared while cached PIN remains, in both variants. The existing full-only multi-chain Initialize test also passes.
Malformed/unexpected tiny input replies once and unwinds	Stack 01's rejected-tiny latch, loop exit and wipes are retained. Published Stack 06 regressions therefore do not justify replaying 189db1d2b wholesale. Valid foreign tiny acknowledgements and short packets still leave waits suspended.	Add waiting-handler type rejection and short-packet termination. Native tests and actual host replies cover malformed size, wrong-handler acknowledgements, normal requests in tiny mode, and short packets.
Synchronous receive packets are erased after callbacks	UDP, main USB, U2F and debug USB source retains the wipes. Stack 02 adds test receive injection; it does not supply all inherited packet hygiene.	USBRX. <code>PacketStorageIsWipedAfterCallback</code> executes in both ordinary variants. Main/debug short-transfer paths still wipe their full storage. U2F remains independently framed. Physical USB remains unverified.
Dispatch boundaries revoke other signers and clear key scratch	Stack 02 defines <code>keepkey_before_message_dispatch</code> and <code>keepkey_after_message_dispatch</code> but <code>messages.c</code> never calls them. Three relevant regressions are guarded.	Restore normal dispatch hook calls, including cleanup; retain weak defaults for board-only linkage. Restore RAW dispatch hooks for parity; no active RAW entry was found in this candidate's firmware message map. Ungate the three regressions. All execute and pass in full; cross-chain acknowledgement coverage is excluded by the Bitcoin-only product configuration.

Historical Git inventory

Each table uses `git show --format= --numstat --no-renames COMMIT_SHA`. Counts include documentation, tests and gitlink lines where shown. These commits overlap; their totals are not the net candidate diff.

71ee8c0bc949fb64f095cb42c930a8b462f3eb3d

Tiny credential copies previously survived consumption; wipe receive storage and handler copies and test stale-secret reuse.

Added	Deleted	Path
27	0	docs/release/audit-units/P02-001-tiny-lifetime.md
1	0	lib/board/confirm_sm.c
10	3	lib/board/messages.c
1	0	lib/firmware/passphrase_sm.c
1	0	lib/firmware/pin_sm.c
64	0	unittests/firmware/usb_rx.cpp

f20c2497a0990a6690c5bb804414c11cac74bf58

Initialize previously left signing workflows alive; abort workflows while preserving the intended cached-PIN policy.

Added	Deleted	Path
21	0	docs/release/audit-units/P02-002-initialize-abort.md
0	13	lib/firmware/fsm.c
2	6	lib/firmware/fsm_msg_common.h
17	2	unittests/firmware/fsm.cpp

041a23d5c7fa7a09492644c4d55ab7f0c5ea22ad

Synchronous UDP and USB packets previously retained consumed data; wipe packet storage, including short-transfer exits.

Added	Deleted	Path
23	0	docs/release/audit-units/P02-003-packet-lifetime.md
3	0	lib/board/udp.c

```

14      3  lib/board/usb.c
39      0  unittests/firmware/usb_rx.cpp

```

5b2a62ce0e653a2478f7c4a74d3243535a02d576

Protected Ping response arena could contain DebugLink data; initialize its response after confirmation. Includes a historical host gitlink change, not replayed here.

```

Added Deleted Path
  1      1  deps/python-keepkey
  2      0  lib/firmware/fsm_msg_common.h

```

32c6555316a203cb6c0b75a6553aafe56825089a

Rejected tiny input could leave its handler waiting or emitting a second response; latch rejection and unwind once.

```

Added Deleted Path
  3      0  include/keepkey/board/messages.h
24      5  lib/board/messages.c
  1      0  lib/board/usb.c

```

cb56504906bfe0470e3ce6601a6a77ad8e9dd309

Format the tiny-failure calls; no independent behavior change.

```

Added Deleted Path
  6      4  lib/board/messages.c

```

Candidate changes and net code/test inventory

The baseline reproduction ran its original implementation with `KK_FINAL_POLICY_TESTS` enabled and failed four selected tests. Applied source from `ba52d68b6` supplies only protected-Ping cancellation; selected `ae4061a6f` hunks supply dispatch hooks and the three P02 test ungates. Its recovery/Ethereum/EOS progress and unlimited-approval changes were not copied. `189db1d2b` supplies the malformed-size regression only, because its production tiny-loop fixes already exist in Stack 02.

- Dispatch/Ping fix `5e20b18c1`: 19 dispatcher lines and 10 Ping lines restore the authorization boundaries; four regressions now execute in ordinary builds; add the malformed tiny-buffer regression.
- Foreign acknowledgement fix `7388977fe`: PIN, passphrase and button handlers reject valid but inappropriate replies using the existing terminal latch, then unwind and erase their temporary copies. Debug state polling remains serviced. Three native negative-control tests distinguish the old behavior.
- Soft Initialize coverage `a6827b7d8`: explicitly verifies retained PIN, revoked Bitcoin signing and cleared passphrase in both configurations.
- Header-order correction `0cf8a82b4`: C++ standard headers precede the firmware `isprint` macro in the new test includes.
- Host coverage `87447127e`: validate one terminal wire response and an immediately usable Initialize round trip for each wrong acknowledgement and a normal request in tiny mode.
- Short-packet fix `2b1143768`: reject short tiny packets in UDP and main/debug USB waits. Normal USB short-packet handling and U2F framing are preserved; no-data reads do not create a failure.
- Host short-packet test `3ade61348`: checks raw UDP truncation gets exactly one Failure and unwinds to Initialize.

Net implementation/test range: `git diff --numstat`

`51411c4a7c96137bc80f8b99fa1690c4e385f7fd..3ade6134877314293749af4e73de9ebf9d9de0c4`. This is the direct P02 remediation delta, not PR #832's entire chains diff.

```

Added Deleted Path
  4      0  include/keepkey/board/messages.h
  5      1  lib/board/confirm_sm.c
35      1  lib/board/messages.c
  8      2  lib/board/usb.c
10      0  lib/firmware/fsm_msg_common.h
  8      0  lib/firmware/passphrase_sm.c
  3      0  lib/firmware/pin_sm.c
  0      8  unittests/firmware/fsm.cpp
21      0  unittests/firmware/storage_passphrase.cpp
110     1  unittests/firmware/usb_rx.cpp
 48      0  unittests/host/test_p02_transport.py

```

Complete local candidate inventory

Generation predecessor: `173752ec4af42f17b8f54af85f1419c1f602d3be`. Reproduce with `git diff --numstat`

`51411c4a7c96137bc80f8b99fa1690c4e385f7fd..173752ec4af42f17b8f54af85f1419c1f602d3be`. This includes the report source,

binary PDF and artifact manifest. The final containing head is recorded in the canonical ledger; no remote review is claimed. Final committed path/count equality is checked after report regeneration.

Added	Deleted	Path
36	0	docs/release/audit-units/P02-requalification-20260923-artifacts.json
227	0	docs/release/audit-units/P02-requalification-20260923.md
-	-	docs/release/audit-units/P02-requalification-20260923.pdf
4	0	include/keepkey/board/messages.h
5	1	lib/board/confirm_sm.c
35	1	lib/board/messages.c
8	2	lib/board/usb.c
10	0	lib/firmware/fsm_msg_common.h
8	0	lib/firmware/passphrase_sm.c
3	0	lib/firmware/pin_sm.c
0	8	unittests/firmware/fsm.cpp
21	0	unittests/firmware/storage_passphrase.cpp
110	1	unittests/firmware/usb_rx.cpp
48	0	unittests/host/test_p02_transport.py

3. Findings and dispositions

ID	Origin and concrete evidence	Disposition
P02-R01	Missing dispatch calls on published Stack 02. Diagnostic baseline fails derived-key cleanup, cross-workflow acknowledgement, and top-level-confirmation signer cancellation.	Fixed locally; all three regressions ungated and pass in their applicable ordinary variants.
P02-R02	Protected Ping enters a credential wait while old signing remains active; exact-baseline diagnostic fails the named test.	Fixed locally by aborting signing before protected Ping/authenticator waits. Ordinary shared regression passes.
P02-R03	Three waiting handlers silently ignore a valid acknowledgement for another handler. Negative control uses original handlers plus new tests, sends trailing Cancel to avoid a hang, and fails all three tests (no terminal rejection).	Fixed locally; all three native cases and wire cases pass. No dependency change.
P02-R04	Tiny parser silently discards non-64-byte input; device main/debug receive callbacks discard short packets before that parser. Negative control leaves type at ERROR, failure count zero and caller buffer uncleared.	Fixed locally. Short UDP native/wire tests pass. ARM builds cover production main USB; debug USB was source-reviewed. Physical transfer testing remains required.
P02-I01	Replay of Stack 02 51411c4a7 onto Stack 01 cec3cac24 conflicts in fsm.c, home_sm.c and unittests/firmware/fsm.cpp. Stack 01 uses sent-response progress; Stack 02 switches to explicit workflow progress.	Pending predecessor integration. Replay was aborted after saving the conflict diff. Do not silently choose a progress policy or restack a shared branch.
P02-I02	Six remaining guarded policy tests were explicitly enabled on pre-short-packet candidate 87447127e. Feature polling passes; Bitcoin stream progress, recovery edits, Ethereum chunks, EOS data progress and padded-zero unlimited approval fail.	Five open inherited failures assigned to workflow-progress/P03/P04/EVM reconciliation. Their implementations and guards are unchanged by the final short-packet fix. They block assembled-candidate acceptance; this receipt claims only the P02 local scope.
P02-I03	Repeating native xunit with the prior run's emulator.img fails Recovery.SpacesOnlyCeremonyIsRefusedAndCommitsNothing at its initial storage_isInitialized() assertion after storage_wipe(), in both variants.	Pending storage/recovery isolation investigation. Logs and both prior images retained. Fresh-image ordinary suites pass, matching the initial isolated-container environment. This is not evidence of warm-image storage compatibility.
F161	Historical candidate omitted the UDP packet regression from Bitcoin-only.	Closed for this local candidate: usb_rx.cpp is unconditional and the named packet-wipe test executes in both variants.
F204	Shared UDP ports may cause interference.	Controlled for these runs by one owned emulator/test process per isolated Docker network namespace with no published ports. Broader CI concurrency still requires its own evidence.

4. Verification and artifact identity

Builder: kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2, Linux amd64 under Docker on this ARM host. Final native and ARM source/test head is 3ade6134877314293749af4e73de9ebf9d9de0c4. Host dependency image: sha256:d1e9562baca19b277ec84fb45814ed4a32e9c08a11b95b86265eb450272db402. Host dependencies come from the pinned source checkout mounted into this immutable host-dependency image; firmware binaries are the audited build outputs, not that image's embedded firmware.

Check	Result	Command / evidence
Original baseline diagnostic	9 tests: 5 pass, 4 fail	Original Stack 02 build with <code>-DKK_FINAL_POLICY_TESTS</code> ; selected P02 and USBRX tests; <code>baseline-focused.xml</code> .
Foreign-ack negative control	3 expected failures	New tests with original handler/transport files overlaid; <code>foreign-baseline.xml</code> .
Short-packet negative control	1 expected failure	New test with original receive implementation overlaid; <code>short-baseline.xml</code> .
Final full ordinary native	419 firmware, 19 board, 18 crypto pass	Emulator Debug clang/clang++ build; make xunit on fresh emulated flash.
Final Bitcoin-only ordinary native	130 firmware, 19 board, 18 crypto pass	Same plus <code>-DKK_BITCOIN_ONLY=ON</code> ; make xunit on fresh emulated flash.
Final host protocol checks	13 pass, zero skipped per variant	Ping, ClearSession and unittests/host/test_p02_transport.py; pinned host tests with <code>KK_FORCE_UDP=1</code> , actual <code>FW_VERSION=7.14.3</code> ; owned emulator.
Report validator	6 pass	Pinned host <code>test_report_variant_validation.py</code> .
ARM full and Bitcoin-only	Both compile	Device cache, <code>-DCMAKE_BUILD_TYPE=MinSizeRel</code> ; production main USB compiled.
SRAM full	PASS	Repository tools/check_sram_budget.py; budget log below.
SRAM Bitcoin-only	PASS	Same gate with <code>--variant bitcoin-only</code> .
Remaining guarded policy diagnostic	1 pass, 5 fail	Explicit diagnostic build; P02-I02 above.
Repeat native with existing flash	FAIL in both variants	Preserved as P02-I03, not counted as a passing compatibility check.
Physical USB/OLED / signed-device upgrade	Not executed	Requires actual device qualification. Emulator tests cannot satisfy it.
Exact-head hosted CI	Pending	No candidate was published or combined matrix dispatched while predecessor/policy gates remain open.

Artifact root: /private/tmp/kk715-p02-audit-evidence. The evidence manifest records SHA256 for logs, XML, emulator/native binaries and ARM ELF files. Build directories and prior flash images remain local. Host transport runner is `host-run.sh`; negative controls use source overlays under `foreign-baseline/`. Original diagnostic build initially lacked the nested token checkout and its first test launcher used unsupported BusyBox timeout syntax; both were corrected before the delivered baseline result recorded here.

Artifact SHA256 manifest

Artifact	SHA256
baseline-focused.log	503d52f16f84e44640a60113a51e7497c255680dfbcd4a8aac8a8da9f6287472
baseline-focused.xml	c3b30bf77360d3273d5c88911b16b3cecc1b63f7c98318cfc6d2673aa99ca471
foreign-baseline.log	aade8ba542576aebf9ecbdc9070c2e009e566a256c9eb082eed17f7db4d2145
foreign-baseline.xml	5620b68e00840df826e8f5addfc091ccc8cda1a08a31645f7749d1bb2068a568

Artifact	SHA256
short-baseline.log	382b18ec4a2d9021b2560e1d1395819f69fedf0b273a6ff126ade4fba768d29e
short-baseline.xml	562c0fc4f770013bc04f72b8cabb9c28e394a277d93414371331fede1e165dc6
full-xunit.log	4ccbbf3b762d36f97d48f5d874d705b86685b5ba0ca9497f53c214d3f8a37688
btc-xunit.log	1b5c17d62097c8edb00f322bf749a9aa67771f0fabe63653fcebdc6cc93bac5c1
full-xunit-existing-flash.log	ff1f3c660e4175e7fa7e34a00c8ae9a27e7f067675a46b44b75a9e52943383
btc-xunit-existing-flash.log	0700e90fe3f22656ddc09f8904228bc239fa923d6ca1a54250f1efeed2d745fe
host-full.log	aac6b1fbee8eed669692a732699e933b5999aed0a8654daa9ee5e6b87db46475
host-full.xml	b611fb84ec43b04aeba26cd084cfbb2bbaf64d7076a881a8bda82ea24660773c
host-btc.log	c75f805dadf89b5e245e727c7610a25ef14bc2480c4c0f962261e78d34862c41
host-btc.xml	4698f40e4b906487d4288ce52d8c1bbe915fd4c7f7389d8b71b844f3a7c9ca60
diagnostic.log	db5beaa21acdea7928b7eb9b253e9950ac5e57e5fdb5f6614ef59f607cb31135
diagnostic.xml	561568dd37cb2ed5e86b4e614b2de910e416d9212ed007cdda84413489fe1a58
report-validation.log	f9e6e463dd6852f16d4939afd481473269bde3bb6f570e01a31f0242ea18d1f1
report-validation.xml	d6fa8eb985a6e46a22f670e37dd5975efe31ccd95ae1b436bf6a2d23a6a9872c
arm-full-budget.log	62236fa05c7e82d22b1577c2d724eafdd3c7a3874ad81f2eb9771200b8f94152
arm-btc-budget.log	88cd241ea83b7e26cc5a75ceee01d273bbe2f94b28f90d1c50eb9d2839988ef8
predecessor-replay-conflicts.patch	18bf2cb4b96a7bb74a4bf54fa2fb5d0d14bbefcfedf0162c43818675a17b12d5
code-diff-gate.log	ee830a16b33bf8dc714b8183a626402c878824bca58f2efab2614fcf350e4a90
host-run.sh	829f0327027d71f3c53a3f123bcbb851d09a3ea9de7e2016f4ffff716283373e
build-full/bin/firmware-unit	b28e42082a43aa231134025b44883d135a860f8c6b58e8fa913d72739cddca88
build-btc/bin/firmware-unit	7115755acb92e3297bb08043ea706b47a9aa03f14acce2346009739edde260d
build-full/bin/kkemu	ae9432a928085c7d6626ea8da41a5a045bfc3c0581ce67b95a16f1cc18c793e0
build-btc/bin/kkemu	ca3beac602fd9d001dda738397d0739d27988ce5192bcd1b332f8e9fa94f68ef
arm-full/bin/firmware.keepkey.elf	626c8727e2915af71e3420a8fd082affff69221efd58994a8326a61b80dbe9ce
arm-btc/bin/firmware.keepkey.elf	8aa316e79e2e8ab598a5552e9f721f2887110628059f27cb7158136bc9954c64

5. Report render and local preflight

- The seven-page PDF was rendered from this Markdown and all pages were visually inspected. Tables, inventories and hashes are legible, with no clipped content.
- `git diff --check` passes on the frozen code/test range. The code-review machine gate identifies eligible implementation and test paths; it is not proof of inherited behavior coverage.
- No submodule pointer or workflow changes are included. Named P02 regressions execute in ordinary builds; remaining guarded tests and their failures are disclosed above.
- The published Stack 02 PR does not yet include this candidate. External-review preflight, final PR inventory including reports, live base/head alignment and accepted predecessor integration remain pending.
- Preserve separate status for local behavior verification, report review, code-review checkpoint, assembled product and release acceptance.

6. Review checkpoint and next integration action

Copilot requests made in this audit: **zero**. Historical receipt reviews do not cover these changes. The SOP allows the late external checkpoint only after the release/upstream-unit acceptance conditions and owner authorization apply; no authorization was inferred from Stack 01's separate recorded request.

Next: resolve the Stack 00b/01 acceptance and workflow-progress interaction on the intended release sequence; port these bounded P02 fixes and regressions; retain or explicitly disposition all five contracts; revalidate the reconciled candidate. Close or assign the five inherited diagnostic failures and investigate the warm-image storage precondition before claiming the assembled candidate is clean. Prepare the final code-bearing adjacent report and PDF, verify its live file list, and request the authorized late review only after the SOP gate is satisfied.

Physical-device, signed-upgrade and release-promotion gates remain separate. Block 2 is not complete.